

ASHAKids | Auditoría de mensajería familiar

Corte AUDIT-2026-10-09-06 — F5-01 / mensajes persistentes

Fecha: 2026-10-09, evidencia de verificaciones 03:58–04:12 America/Lima. Responsable: desarrollo en clon de Piero; ejecución asistida documentada.

Repositorio: <https://github.com/sromansilva/ashakids-platform> . Rama auditada: dev. Base: 1398e706121fea153fe9f7481d24983d9e49911a (V07_Integracion_Reportes_PDF, PR105 integrado). Código auditado: 7fddd59d6cc6ec594c666c9c80ba184a88c9a91d, V08_Mensajes_Familia_Terapeuta. Pruebas realizadas sobre ese contenido antes del commit; documentación/evidencias se añaden después en V09_Auditoria_Mensajeria.

Árbol: código comprometido; documentación de este corte en preparación. Entorno: API8001 / web5174 / PostgreSQL17.6 local6544, ashakids_test_compat17; identidades y datos sintéticos existentes. API8000/web5173, Supabase y despliegue no se auditaron. Entrega académica: 2026-10-09 18:00 Lima.

01. Dictamen ejecutivo

El intercambio familiar/profesional está implementado y tiene persistencia real comprobada por HTTP local. Otra familia o profesional ajeno no lee ni envía en ese chat. La interfaz reemplaza conversaciones/respuestas ficticias, conserva borradores tras error y confirma solo una respuesta válida del servidor. Fase5 sigue abierta para aceptación conjunta y visual; esta auditoría no certifica toda la plataforma.

Indicador	Resultado nuevo	Evidencia y alcance
Frontend	232 aprobadas, 0 fallos/omisiones	Vitest/jsdom; 16 nuevas de mensajes, no navegador real
Backend	36 aprobadas, 0 fallos/omisiones/advertencias	25 mensajes + 11 regresión PDF; DB simulada en unidad
HTTP / persistencia	53 respuestas verificadas + OpenAPI	API8001 y PostgreSQL real; 7 mensajes nuevos en corrida final
Ingeniería	25 rutas; tipos/check/build correctos	318 fuentes, máximo495 líneas; detector UI sin hallazgos
UI visual	Pendiente en este corte	Bloqueo previo de acceso del navegador; no nuevas capturas

Dos corridas HTTP crearon siete mensajes cada una: catorce sintéticos conservados en la conversación1. La segunda recorrió los catorce por cursor sin IDs repetidos. No se copiaron datos reales ni se reiniciaron fixtures.

02. Arquitectura y cambios realizados

React/TypeScript -> messagingService -> apiClient/cookie -> FastAPI -> servicio mensajería -> SQLAlchemy/asyncpg -> PostgreSQL. Autenticación propia; Supabase continúa como infraestructura prevista. ADR0007 registra participantes, conservación de historial y actualización manual.

Python3.13.7; FastAPI0.143.0; SQLAlchemy2.1.4; asyncpg0.32.0; pytest9.1.1; httpx0.28.1. No dependencias nuevas en este corte. Se mantiene el runtime de PDF anterior. Vite genera assets de producción; el servidor de desarrollo no es hosting.

Capa / archivos	Cambio comprobado
backend/app/models/mensajería.py	Mapea tablas existentes; sin create_all ni DDL
schemas / api/v1/mensajería.py	Entradas estrictas, contactos, detalle, cursor y envío201
services/mensajería.py / main.py	Participantes, asignación, bloqueos y router registrado
MessagesCenter / MessageThread	Lista/chat compartidos por dos roles; carga, error, borradores y texto literal
PadreMensajes / TerapeutaMensajes	Entradas conectadas; administración explica campañas pendientes sin envío ficticio
pruebas / verify_messaging.py	Casos unitarios, componentes y guion HTTP local con guardas

Modelo físico reutilizado: conversaciones.id_conversacion INTEGER identity PK; id_tutor FK NOT NULL -> tutores, id_terapeuta FK nullable -> terapeutas, estado VARCHAR20 y fechas TIMESTAMPTZ. mensajes.id_mensaje INTEGER identity PK; id_conversacion FK NOT NULL, id_usuario_emisor FK nullable -> usuarios, texto TEXT nullable, fecha TIMESTAMPTZ y leído BOOL. Solo texto nuevo; datos históricos nulos se presentan honestamente.

Tablas, FK e índices proceden de la réplica del corte02, cuya equivalencia con Supabase es evidencia histórica. No se volvió a comparar el esquema compartido ni se crearon índices. No UNIQUE para la pareja: bloqueo del tutor serializa aperturas de esta API, sin corregir duplicados legacy ni garantizar escritores externos.

03. APIs funcionando: identidad y participantes

Cada consulta exige sesión válida y roles PADRE/TERAPEUTA por perfil vinculado al usuario. ADMIN solo no concede acceso privado. Contactos surgen de pacientes activos, tratamiento ACTIVO y ambos usuarios habilitados, sin directorio general ni nombres ficticios.

Método y ruta	Estado	Regla / evidencia
POST /auth/login	200	Cinco cuentas sintéticas; cookies independientes
GET /conversaciones, anónimo	401	Sin acceso a listas privadas
GET /conversaciones, ADMIN	403	Rol administrativo sin permiso de chat
GET /conversaciones/contactos	200	Familia y terapeuta asignados ven la misma pareja; otros dos ven lista vacía
POST /conversaciones	200	Dos aperturas simultáneas devuelven conversación1, sin dos chats nuevos
POST /conversaciones, pareja ajena	403	Otro padre/profesional no inicia el chat
GET /conversaciones/{id} o /mensajes	404	Recursos ajenos/no existentes no se revelan
GET /conversaciones/{id}/mensajes, ADMIN	403	Rechazo explícito de rol no participante

Contactos se pagina mediante limit/offset y X-Total-Count; React reúne las páginas con el cliente existente. La lista de conversaciones usa ID descendente y next_before_id; no ordena por presencia ni simula disponibilidad.

Historial: el participante conserva lectura cuando termina la asignación. Estado cerrado o fecha_archivado impide envío con409; falta de asignación activa impide envío con403. Estas transiciones se comprobaron en unidades con dependencias simuladas: no se cambió un tratamiento o paciente para reproducirlas en SQL.

Las operaciones anteriores no constituyen un nuevo ensayo de CRUD de pacientes/usuarios/tratamientos. Esos recorridos y permisos permanecen como evidencia de cortes anteriores, sin sumar sus cifras a este informe.

04. APIs funcionando: intercambio y persistencia

Operación / caso	Resultado final	Evidencia real o simulada
POST /{id}/mensajes	201	Familia envía español/emoji/markup literal; terapeuta responde
Cinco envíos simultáneos	Cinco201	API bloquea conversación; IDs distintos guardados en PG
GET /{id}/mensajes, limit2	Cursor válido	Recorrido final14 mensajes, sin IDs duplicados, incluye siete nuevos
Logout/login y lectura posterior	JSON idéntico	Misma identidad vuelve a leer historial guardado
GET /conversaciones, limit1	Lista propia	Participantes ven el chat; otros no lo ven
Blanco, 4001 caracteres, NUL, sender extra	422	Entrada rechazada antes de guardar texto inválido
limit101, cursor0/fuera de INTEGER, ID0/fuera de INTEGER	422	Validación de rango HTTP y unidad
API caído /503 / respuesta inválida	Borrador conservado	Pruebas frontend con fetch simulado; POST sin retry automático

El emisor proviene del usuario autenticado; el cliente no envía leído/fecha/usuario. La transacción existente hace commit antes de respuesta exitosa. ultima_actividad se actualiza en el servidor; leído no se usa como confirmación de lectura. No hay respuesta automática del profesional.

Evidencia HTTP final: docs/evidence/audit-2026-10-09-06/http-messaging.json, marcador AUDIT-2026-10-09-06-75c05397, conversación1. Corrida previa: http-messaging-first.json, 47 respuestas + OpenAPI y siete mensajes. No sumar ambas como53 casos diferentes. Cinco logout auxiliares de limpieza quedan fuera del contador, sin afirmar resultados no verificados.

El guion no crea usuarios, no modifica filas clínicas, no ejecuta TRUNCATE ni DDL. Login/logout sí crea/revoca sesiones sintéticas. Los siete mensajes nuevos se preservan en cada corrida; repetir añade otros siete. No dirigir estas pruebas a la BD compartida.

05. Capacidades pendientes y alcance

Capacidad	Estado actual	Siguiente acción concreta
Revisión visual mensajes	Sin navegador nuevo en corte06	Confirmar desktop/móvil, teclado y composición con dos cuentas
Actualización de respuestas	Botón Actualizar	No se declara tiempo real, presencia o polling
Adjuntos / Llamadas / leído	Ausentes en este mínimo	Interfaz informa solo texto; no prometer estas funciones
Borradores duraderos	Solo memoria por chat	Cambiar de chat conserva texto; recargar/salir puede perderlo
Reportes PDF	Corte05 implementado	Unidad de regresión nueva; recaptura móvil final todavía pendiente
Campañas ADMIN / recursos	Pendientes/diferidos	Sin botones que aparenten envío o catálogo ficticio
Mundo ASHA	Etapas MA independiente	Borrador/calculador anterior; no juegos completos certificados
Pagos	Fuera de alcance	Sin pasarela, cobros ni nueva tarea de pagos simulados
Hosting	No seleccionado	Comparar opciones cuando el alcance esté estable y aceptado

El bloqueo de navegador es un antecedente del corte05: la preferencia guardada negó acceso al origen de desarrollo. En este corte no se repitió la acción ni se usó otra superficie para eludirla. Las pruebas jsdom y la compilación no sustituyen aceptación visual real. Las capturas05 no se reutilizan como evidencia de mensajes.

F5-01 mínimo seleccionado: PDF guardado + mensajería autorizada + aceptación conjunta. Código de ambos módulos está disponible; falta esa aceptación final y la reproducción por otro integrante. No se marca toda fase5 completa ni se inicia una extensión avanzada solo por terminar estos endpoints.

No hay certificación clínica, firma digital, ensayo de despliegue, carga o auditoría completa nueva del backend. Incidencia histórica01 conserva su estado abierto hasta revisarla explícitamente.

06. Seguridad y riesgos priorizados

Prioridad	Hallazgo y comprobación	Acción / límite
Alta	Recurso ajeno404; ADMIN403; entrada extra422	Mantener permisos del servidor; claves de caché por identidad no conceden autorización
Alta	No comparación compartida nueva; incidencia01 abierta	Revisar incidencia y entorno antes de declarar estabilidad/desplegar
Media	Respuesta perdida puede ocultar mensaje ya guardado	POST sin clave idempotente; actualizar antes de reenviar, no auto retry
Media	Sin UNIQUE pareja; no garantía entre escritores externos	Bloqueo válido para esta API; medir/revisar migración si se amplían escritores
Media	Revisión visual final y segundo clon pendientes	No certificar dispositivos o reproducción por terceros sin ejecutar
Baja	No carga, retención, búsqueda ni índice cursor compuesto nuevo	Medir volumen y requisitos antes de ampliar arquitectura

React muestra markup como texto: la prueba de componente con cadena HTML no genera un elemento img. La corrida SQL conserva texto con etiquetas y emoji; no prueba ejecutarlos en un navegador. NUL se rechaza antes de PostgreSQL. Las consultas usan SQLAlchemy parametrizado; el contenido no se concatena como SQL.

Un chat archivado o sin asignación conserva historial a sus participantes. No se permite restaurarlo desde este módulo. Revocar la relación desde un escritor externo simultáneo no es una garantía atómica del bloqueo de conversación: el esquema y las demás escrituras no cambian en este corte.

Se reutiliza cookie HttpOnly, validación de sesión/origen y apiClient existentes. Esta auditoría no vuelve a certificar atributos de cookie HTTPS/CORS en un dominio desplegado. La revisión dirigida de secretos comprueba textos cambiados y PDF extraído contra valores sensibles locales y patrón JWT, sin imprimirlos; no es detección exhaustiva ni pentest.

No se han escrito datos de pacientes reales ni credenciales en las evidencias. Fixtures sintéticas y filas de mensajes se conservan para una demostración repetible.

07. Pruebas, comandos y rúbrica

Comando / entorno	Resultado final	Archivo de evidencia
pytest tests/test_mensajeria.py tests/test_report_pdf.py -q -p no:cacheprovider	36 correctas, 0 advertencias	backend-unit-tests.xml
npm run test:components, reporter JUnit	232 correctas en12 archivos	frontend-tests.xml
npm run test:routing	25 correctas	routing-tests.txt
npm run typecheck / check:frontend / build	Sin errores	typecheck.txt, frontend-check.txt, build.txt
python -m scripts.verify_messaging --output ../docs/evidence/audit-2026-10-09-06	53 HTTP + OpenAPI	http-messaging.json
knowledge/manage.py refresh / check	Mapa actual	knowledge-check.txt

Los comandos Python usan backend/.venv313 desde backend, salvo knowledge desde raíz. Guion HTTP exige ASHAKIDS_ALLOW_ISOLATED_LIVE_TESTS=1, API8001 y DATABASE_URL idéntica a ASHAKIDS_TEST_DATABASE_URL en BD local ashakids_test_*; no serializar URL/secretos. Ver README de evidencia para reproducción.

Fallo inicial frontend:230 casos,229 correctos/1 fallo; una expectativa antigua clasificaba mensajes como demo. Se corrigió tras conectar el módulo. Luego230 correctos; se añadieron dos validaciones de respuesta POST y finalizaron232 correctos. JUnit inicial preservado; no ocultar esa ejecución. Unidades ampliadas de31 a36 al cubrir límites INTEGER. No suite backend completa nueva.

Build: índice292.85kB / gzip92.55kB. Es tamaño de asset, no tiempo de carga ni benchmark. Detector mecánico UI: sin hallazgos, una ejecución; no sustituye revisión visual. Graphify AST local/no-label con fallback Windows, sin analizar datos/credenciales.

Rúbrica visible	Evidencia disponible	Límite práctico
Arquitectura/backend	Capas, endpoints y ADR0007	Sin nueva arquitectura de despliegue
BD física/operaciones	FK históricas y lectura SQL persistente nueva	Equivalencia compartida del corte02 no reensayada
Seguridad/validación/pruebas	Permisos, entradas, cursor y concurrencia acotada	No pentest/carga; interfaz real pendiente

08. Cierre y ruta de entrega

Mensajería está implementada y verificada en unidad, componentes y HTTP/PostgreSQL local. La aceptación visual y de conjunto de F5-01 permanece pendiente. Código V08 ya existe; fuente/PDF/evidencias/contexto se preparan en V09 y se publican mediante PR hacia dev, merge V10_Integracion_Mensajería. Al generar este PDF no se declara concluido un push o merge futuro: consultar PR/historial para su SHA efectivo.

1. Actualizar dev por fast-forward y conservar los .env ignorados. Otro clon instala requisitos backend y dependencias frontend del README; no se añadió un paquete nuevo en06. Generar mapa local sin versionarlo.
2. En API8001/web5174/PG17.6 local6544, usar la demo sintética conservada: familia abre Mensajes, inicia contacto asignado, envía; profesional actualiza, responde; familia actualiza y confirma historial tras volver a iniciar sesión. Confirmar teclado y tamaños desktop/móvil cuando el navegador permita acceso.
3. Repetir aceptación del núcleo con tres roles, reporte guardado/PDF y conversación privada. Verificar ausencia de acceso ajeno y que falla de API conserva formularios. La reproducción del siguiente integrante necesita evidencia propia; no repetir reset sobre esta demo.
4. Revisar incidencia01, reunir evidencias por rúbrica y preparar guion de entrega antes de las 18:00. Mantener pagos excluidos, recursos diferidos y Mundo ASHA en etapa propia. Hosting se compara con documentación vigente cuando el alcance seleccionado sea estable.

Continuidad: docs/PROJECT_CONTEXT.md, IMPLEMENTATION_PLAN.md, IMPLEMENTATION_PROGRESS.md, DELIVERY_CHECKLIST.md, architecture.md y ADR0007; índice docs/audits/README.md. Fuentes/JSON/JUnit sanitizados en docs/evidence/audit-2026-10-09-06; PDF en output/pdf/Auditoria_Mensajería_AshaKids_2026-10-09-06.pdf. Conservar informes05 y anteriores.

Repositorio de entrega: <https://github.com/sromansilva/ashakids-platform> . El informe registra el código auditado y sus límites; la versión V08 no equivale a la versión 0.1.0 de la API.